

Estudo de Casos Práticos e Lições de Controle

Fraude Fiscal · Riscos LGPD · Inteligência Artificial em Auditoria

2025 — Material técnico de referência

CASO 1: FRAUDE FISCAL

CASO 2: RISCOS LGPD

IA EM AUDITORIA

Este documento apresenta dois casos práticos de auditoria interna, abordando fraude tributária por manipulação de notas fiscais e falhas de conformidade com a **LGPD**, ilustrando as limitações dos controles tradicionais e a transição para soluções baseadas em **Inteligência Artificial** adaptativa.

CASO 1

Fraude Transacional por Manipulação de Notas Fiscais e a Transição para IA

Em um caso emblemático de fraude corporativa no cenário tributário brasileiro, o gerente financeiro de uma rede varejista **adulterou intencionalmente** o valor e o registro de notas fiscais de venda diretamente nos bancos de dados, com o objetivo de **sonegar o pagamento de ICMS**. Sob a ótica da auditoria interna e da norma **NBC TI**, a ação configurou-se como fraude — distorção intencional de registros para ganho ilícito — e não como mero erro operacional, demonstrando falhas graves nos controles internos de processamento de dados.

CLASSIFICAÇÃO NORMATIVA · NBC TI

A conduta foi tipificada como **fraude** (e não erro), pois há intenção deliberada de distorcer registros para obter vantagem ilícita — neste caso, a supressão de tributos devidos. A norma NBC TI diferencia as duas categorias com base no elemento volitivo: ausência de intenção = erro; presença = fraude.

Limitações dos Sistemas Tradicionais de Monitoramento

A investigação de fraudes em larga escala evidencia as limitações dos sistemas **SIEM** (Security Information and Event Management) baseados em **regras estáticas** de controle. Fraudadores internos refinam continuamente suas táticas para contornar limites preestabelecidos, visando principalmente **contas com credenciais administrativas** para apagar trilhas de auditoria.

Dimensão	Monitoramento Tradicional (SIEM)	IA com Aprendizado Adaptativo
Detecção de padrões	Regras fixas e limites estáticos	Análise comportamental contínua
Adaptação a novas táticas	Manual — requer reprogramação	Automática via aprendizado de máquina
Falsos positivos	Alto volume	Reduzido — foco em desvios reais
Escalabilidade	Limitada a volumes massivos	Alta — opera em grandes volumes
Contexto geográfico	Regras genéricas	Limites ajustados por região
Foco do auditor	Triagem manual extensiva	Desvios já priorizados pela IA

Para **operações multinacionais**, o aprendizado adaptativo é ainda mais crucial: transações de cartão de crédito predominam nos **EUA**, pagamentos móveis lideram na **China** e transações em espécie dominam no **Leste Europeu**. O modelo ajusta automaticamente os limites de detecção para cada contexto geográfico, assegurando a precisão do controle sem intervenção humana contínua.

LIÇÕES APRENDIDAS

- ✓ Sistemas SIEM com regras estáticas são insuficientes para fraudes internas refinadas.
- ✓ A IA adaptativa reduz falsos positivos e direciona o esforço do auditor para anomalias reais.
- ✓ O aprendizado por contexto geográfico é indispensável em operações multinacionais.
- ✓ Contas com privilégios administrativos devem ter monitoramento comportamental intensificado.

CASO 2

Incidentes de Acesso e Riscos de Conformidade com a LGPD

Uma empresa de tecnologia identificou **falhas graves de rastreabilidade** em seus registros de sistema. Eventos locais de servidores, logs de conexões externas de firewalls e acessos a dados em suítes de produtividade na nuvem estavam espalhados em **repositórios desvinculados**, impossibilitando uma visão consolidada das atividades de acesso.

PROBLEMA CENTRAL · FRAGMENTAÇÃO DE LOGS

Sem um repositório centralizado e imutável, a empresa não conseguia correlacionar eventos entre sistemas distintos (servidor on-premise, firewall perimetral e nuvem), criando pontos cegos críticos para a auditoria de segurança.

Exposição à Lei Geral de Proteção de Dados (LGPD)

A falta de inventário de hardware atualizado permitiu que **dispositivos não autorizados** se conectassem à rede sem cruzamento de logs correspondentes. Esse cenário gerou exposição crítica perante a **LGPD (Lei 13.709/2018)**, que impõe a obrigação de demonstrar de forma clara — em caso de incidente ou requisição de titular — **quem acessou dados pessoais, quando e com qual finalidade regulamentar**.

Obrigação LGPD	Situação Identificada	Risco / Impacto
Rastreabilidade de acessos	Logs fragmentados e desvinculados	Impossibilidade de auditoria completa
Identificação de responsáveis	Inventário de hardware desatualizado	Dispositivos não autorizados na rede
Demonstração de finalidade	Sem política de acesso documentada	Violação do princípio da necessidade
Resposta a incidentes	Ausência de SIEM centralizado	Atraso na contenção e notificação
Relatório de impacto (RIPD)	Dados de acesso sem rastreio	Impossibilidade de elaborar RIPD

A lição aprendida forçou a empresa a **reestruturar seus processos** de segurança, centralizando os registros em um **repositório imutável** e estabelecendo controles rígidos de segurança lógica para validação contínua de acessos a dados sensíveis.

LIÇÕES APRENDIDAS & AÇÕES CORRETIVAS

- ✓ Logs fragmentados inviabilizam a resposta a incidentes e a conformidade com a LGPD.
- ✓ O inventário de ativos de TI deve ser atualizado em tempo real e cruzado com logs de acesso.
- ✓ Repositório centralizado e imutável (ex.: SIEM com armazenamento append-only) é requisito mínimo.
- ✓ A LGPD exige que a organização comprove finalidade e legitimidade de cada acesso a dados pessoais.
- ✓ Dispositivos não gerenciados representam vetor crítico de vazamento de dados.

REFERÊNCIAS

- [9] Aula 01 – Fraude e erro · Qconcursos. Disponível em: vali.qconcursos.com/odin/topics/a608f18a-dce5-4e4d-aeed-711d2d813224.pdf
- [10] Auditoria de Logs de TI: Acessos e Anomalias | Conheça e Aprenda · Eunerd. Disponível em: encontreunerd.com.br/artigos/ti-desorganizada/auditoria-de-logs-de-ti
- [33] O papel da auditoria interna na detecção de fraudes com IA · Wolters Kluwer. Disponível em: wolterskluwer.com/pt-br/expert-insights/internal-audits-role-ai-fraud-detection